Auditing a Windows machine with PowerShell

Week 5 · lab VM · read-only script

Evidence pack. Personal details are masked.

Three questions, three tools

1 **Who exists on this machine?**

`Get-LocalUser · Get-LocalGroupMember`

2 **Who can write where?**

`icacls`

3 **What starts by itself?**

`Run keys · scheduled tasks · services`

System32 is protected

```
PS C:\Users\xxxxxx> icacls C:\Windows\System32\Whoami.exe
C:\Windows\System32\Whoami.exe NT SERVICE\TrustedInstaller:(F)
                               BUILTIN\Administrateurs:(RX)
                               AUTORITE NT\Système:(RX)
                               BUILTIN\Utilisateurs:(RX)
                               AUTORITÉ DE PACKAGE D'APPLICATION\TOUS LES PACKAGES D'APPLICATION:(R
X)
                               AUTORITÉ DE PACKAGE D'APPLICATION\TOUS LES PACKAGES D'APPLICATION RE
STREINTS:(RX)

1 fichiers correctement traités ; échec du traitement de 0 fichiers
```

icacls on whoami.exe: users get (RX). Only TrustedInstaller has (F), full control.

My own folder is not

```
PS C:\Users\[redacted] > icacls C:\Users\[redacted]\Documents
C:\Users\[redacted]\Documents AUTORITE NT\Système:(I)(OI)(CI)(F)
                              BUILTIN\Administrateurs:(I)(OI)(CI)(F)
                              [redacted](I)(OI)(CI)(F)

1 fichiers correctement traités ; échec du traitement de 0 fichiers
PS C:\Users\[redacted]>
```

icacls on my Documents folder: my account has (F). Same rights as an attacker running under my account.

What starts by itself

```
=== Startup programs (Run Keys) ===
Current user (HKCU)



OneDrive                                                    : "C:\Users\xxxxxxx\AppData\Local\Microso
                                                              ft\OneDrive\OneDrive.exe" /background
MicrosoftEdgeAutoLaunch_xxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxx : "C:\Program Files (x86)\Microsoft\Edge\A
                                                              pplication\msedge.exe"
                                                              --no-startup-window --win-session-start



All users (HKLM)

SecurityHealth : C:\Windows\system32\SecurityHealthSystray.exe



=== Scheduled taks outside \Microsoft\Windows ===


TaskPath : \
TaskName : OneDrive Reporting Task-xxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxx
State    : Ready

TaskPath : \
TaskName : OneDrive Standalone Update Task-xxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxx
State    : Ready

TaskPath : \Microsoft\XblGameSave\
TaskName : XblGameSaveTask
State    : Ready



=== END OF AUDIT ====
```

Sample output. OneDrive starts from my profile folder. SecurityHealth starts from System32.

The audit script

*audit-windows - Bloc-notes

Fichier Edition Format Affichage Aide

```
Write-Output "=== WINDOWS AUDITS ==="
Get-Date
Write-Output "Machine : $env:COMPUTERNAME"
Write-Output "User : $env:USERNAME"
Write-Output ""
Write-Output "=== Local accounts ==="
Get-LocalUser | Select-Object Name, Enabled
Write-Output ""
Write-Output "=== Members of the Administrators group ==="
Get-LocalGroupMember -SID S-1-5-32-544 | Select-Object Name
Write-Output ""
Write-Output "=== Services ==="
$running = (Get-Service | Where-Object {$_.Status -eq "Running"}).Count
$stopped = (Get-Service | Where-Object {$_.Status -eq "stopped"}).Count
Write-Output "Running services: $running"
Write-Output "Stopped services: $stopped"
Write-Output ""
Write-Output "=== Startup programs (Run Keys) ==="
Write-Output "Current user (HKCU)"
Get-ItemProperty "HKCU:\Software\Microsoft\Windows\CurrentVersion\Run" | Select-Object * -ExcludeProperty PS* | Format-List
Write-Output "All users (HKLM)"
Get-ItemProperty "HKLM:\Software\Microsoft\Windows\CurrentVersion\Run" | Select-Object * -ExcludeProperty PS* | Format-List
Write-Output ""
Write-Output "=== Scheduled taks outside \Microsoft\Windows ==="
Get-ScheduledTask | Where-Object {$_.TaskPath -notLike "\Microsoft\Windows\*"} |Select-Object TaskPath, TaskName, State | F
Write-Output "=== END OF AUDIT ===="
```

Six sections: machine, accounts, administrators, services, startup keys, scheduled tasks. It only reads.

Two questions for any program that starts by itself

1 Where does it run from?

2 Who can modify it?

A protected location and a protected entry make persistence hard. A writable one makes it easy.